MODULE 1

Cybersecurity Primer

The Foundations of Modern Risk

COLUMBIA

1.1 Mega-Breach Patterns Overview

The Supply Chain and MFA Era

COLUMBIA

Brief History of Cybersecurity

While early research into cybersecurity started in the 1970s (before the term “cybersecurity” existed), mega data breaches started after the commercialization of the Internet in the **1990s**.

In **2003**, the first state Data Breach Notification Act went into effect in CA.

In **2004**, CardSystems experiences a breach of 40 million credit card numbers.

In **2013**, mega-breaches started with Target, JPMChase, OPM, Yahoo! and others.



COLUMBIA

Over 10k breaches in 15 years

2013 — Target

2014 — JPM Chase & Yahoo

2015 — OPM

2016 — Meta (Facebook)

2017 — Equifax

2020s — More …

COLUMBIA

1.2 Root Causes of Breaches

COLUMBIA

Root Causes of Breaches (Representative)

MANAGERIAL	TECHNICAL
Prioritization of Cybersecurity	Account Takeover
Investment in Cybersecurity	Malware (Malicious Software)
Execution of Cybersecurity Initiatives	Software and Supply Chain Vulnerabilities

COLUMBIA

1.3 Early Mega-Breaches

Early Mega-Breaches

Early mega-breaches occurred due to “supply chain” compromises and lack of multi-factor authentication.

- **Supply Chain Compromise**
  - The organization itself was not directly compromised, but compromised through a supplier.
- **Multi-Factor Authentication**
  - Requires checking identity not just based on something a user knows (e.g., a password), but also with something the user has (a device) or is (biometrics)



Representative Mega-Breaches

2013

Target

40+ Million Credit Card Data

CEO and CISO fired

Board sued

$250M in breach costs

Reputational damage

2014

JPM Chase

70+ Million Customer Names and Emails

Potential for mass, targeted phishing attacks

2015

Office of Personnel Management (OPM)

21.5M background checks for US government agencies, including SF-86 forms and 5.6M fingerprints

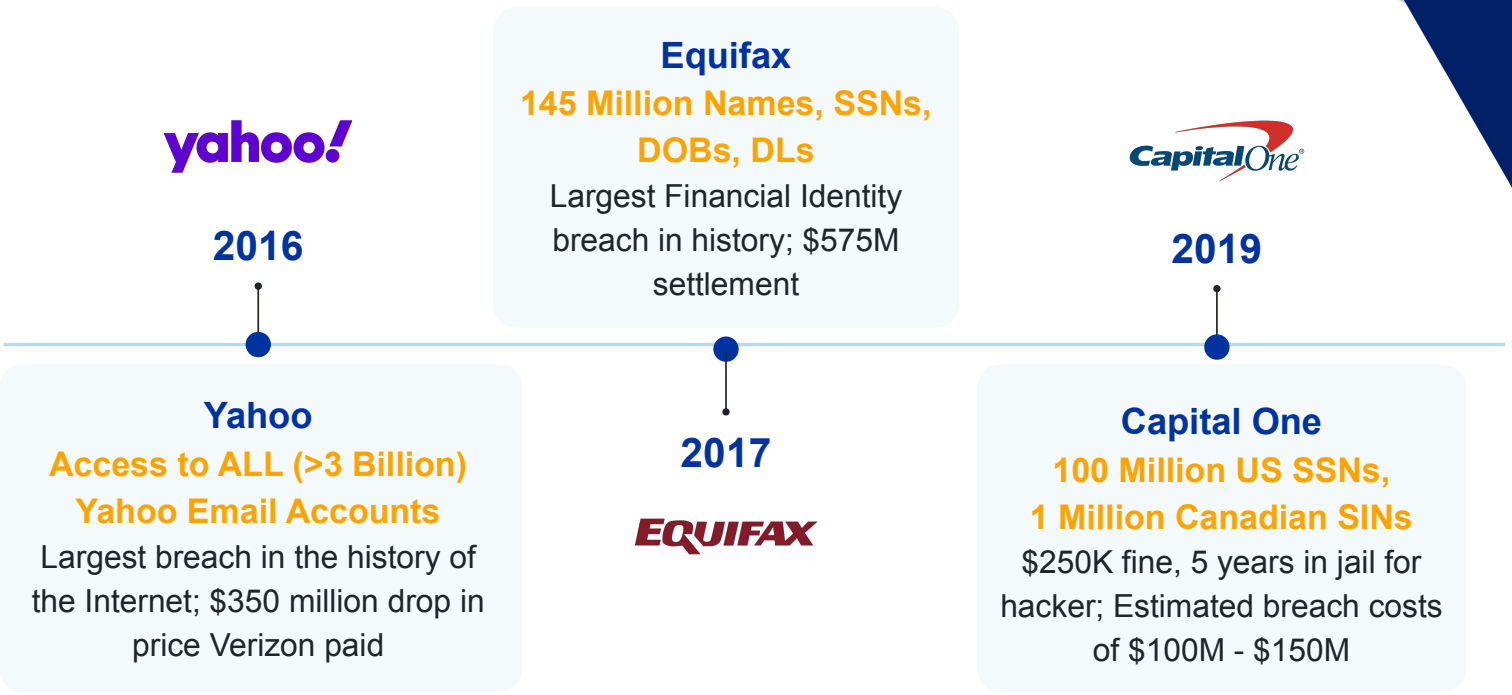
"(impact) cannot be overstated, nor will it ever be fully known."

COLUMBIA

1.4 Tech Mega-Breaches

COLUMBIA

Representative Mega-Breaches



COLUMBIA

1.5 Nation-State Breaches

COLUMBIA

SolarWinds Data Breach (2020)



Russian-nation-state adversary planted a backdoor in SolarWinds software used by US Government Agencies (and 18,000 others)

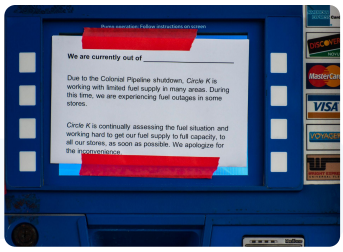
Impact

- Congressional Hearings
- President issues executive order requiring federal agencies to have SBOM (software bill of materials) for all procured software

Key Takeaways

- Third-Party Compromise / Supply Chain Attacks can use a smaller single party to compromise a very large number of customers (as opposed to just one in the case of Target)

Colonial Oil Pipeline Data Breach (2021)



Attacker stole VPN password from dark web and planted ransomware

Impact

- Oil pipeline shut down for a week; ransomware deemed to be a national security threat

Root Causes

- No 2FA

Preventative Countermeasures

- Monitoring dark web for credential theft
- Strong 2FA

1.6 Ransomware

Modern Ransomware: A National Security Threat

Modern ransomware has the following characteristics:

Double extortion is now common

The ransomware encrypts the data and also ”ex-filtrates” (steals) it so attacker can blackmail victim on an ongoing basis.

Targets and encrypts online backups

Offline backups are required for resilience against ransomware.

Attackers get in via multiple channels

In addition to traditional means used to spread viruses and worms, attackers can get in via weak or non-existent multi-factor authentication, phishing, etc..

Key Points on Breach Pattern

- The biggest breaches have occurred due to a fairly stable set of managerial and technical root causes. Much of it amounts to "**cybersecurity hygiene**."
- **Managerial root causes**: failure to prioritize, invest in, and execute on cybersecurity initiatives
- **Technical root causes**: account takeover, malware, supply chain and software vulnerabilities, encrypted data, inadvertent employee mistakes, and insider attacks